

SafeDeserializationHelpers

SafeDeserializationHelpers - zyanfx, GitHub.

- Published: date not stated
- Original: <https://github.com/zyanfx/SafeDeserializationHelpers>
- Preserved from: <https://github.com/zyanfx/SafeDeserializationHelpers> (preserved-copy) on 2026-08-04
- Repository commit: 73cd519490f5b093359fbab2db658c281e7a6daa
- Licence: see the repository

Rights remain with the original author and publisher. This is a research archive of a source cited by ysonet, kept so the technique survives the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Repository reading copy: selected documentation at the recorded commit. Source code is never checked out, built or run.

- Repository: <https://github.com/zyanfx/SafeDeserializationHelpers>
- Commit: 73cd519490f5b093359fbab2db658c281e7a6daa
- Documents preserved: 2

LICENSE

Blob e5500b066566 , 1072 bytes, at commit 73cd519490f5 .

MIT License

Copyright (c) 2018 Alexey Yakovlev

Permission is hereby granted, free of charge, to any person obtaining a copy of this software and associated documentation files (the "Software"), to deal in the Software without restriction, including without limitation the rights to use, copy, modify, merge, publish, distribute, sublicense, and/or sell copies of the Software, and to permit persons to whom the Software is furnished to do so, subject to the following conditions:

The above copyright notice and this permission notice shall be included in all copies or substantial portions of the Software.

THE SOFTWARE IS PROVIDED "AS IS", WITHOUT WARRANTY OF ANY KIND, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO THE WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE AND NONINFRINGEMENT. IN NO EVENT SHALL THE

AUTHORS OR COPYRIGHT HOLDERS BE LIABLE FOR ANY CLAIM, DAMAGES OR OTHER LIABILITY, WHETHER IN AN ACTION OF CONTRACT, TORT OR OTHERWISE, ARISING FROM, OUT OF OR IN CONNECTION WITH THE SOFTWARE OR THE USE OR OTHER DEALINGS IN THE SOFTWARE.

README.md

Blob 2c7e3d397244, 4057 bytes, at commit 73cd519490f5.

Zyan.SafeDeserializationHelpers

This tiny library tries to fix several known BinaryFormatter vulnerabilities. When a malicious payload is detected, the library throws an `UnsafeDeserializationException` instead of deserializing the data that is able to produce bad side effects.

[\[image: GitQ\]](#) [\[image: appveyor\]](#) [\[image: tests\]](#) [\[image: nuget\]](#)

Deserializing the untrusted data is dangerous

It's proven that deserializing arbitrary payloads under certain conditions can trigger code execution. BinaryFormatter, DataContractSerializer, XmlSerializer, as well as several widely used JSON serializers are known to be vulnerable.

See ysoserial.net project for details.

Code sample

```
// unsafe: deserialization can trigger arbitrary code execution
var fmt = new BinaryFormatter();
var object = fmt.Deserialize(stream);

// safe: deserialization is guarded against known vulnerabilities
var fmt = new BinaryFormatter().Safe();
var object = fmt.Deserialize(stream);
```

Usage

1. Install [Zyan.SafeDeserializationHelpers](#) nuget package.
2. Use `new BinaryFormatter().Safe()` instead of just `new BinaryFormatter()`.
3. For .NET Remoting projects, use safe versions of the binary formatter sinks:
 - Replace `BinaryClientFormatterSinkProvider` with `SafeBinaryClientFormatterSinkProvider`.
 - Replace `BinaryServerFormatterSinkProvider` with `SafeBinaryServerFormatterSinkProvider`.

4. Make sure to test your project against payloads produced by ysoserial.net gadgets.

Known vulnerabilities supported by the library

- **ActivitySurrogateSelector** gadget by James Forshaw (loads an assembly and executes arbitrary code).
- **PSObject** gadget by Oleksandr Mirosh and Alvaro Munoz. Target must run a system not patched for CVE-2017-8565.
- **TypeConfuseDelegate** gadget by James Forshaw (runs any process using Process.Start delegate).
- **DataSet** gadget by James Forshaw (unsafe BinaryFormatter deserialization).
- **WindowsIdentity** gadget by Levi Broderick (unsafe BinaryFormatter deserialization).

References

- [Exploiting .NET Managed DCOM](#) by James Forshaw
- [Are you my Type?](#) by James Forshaw
- [Attacking .NET serialization](#) by Alvaro Munoz
- [Friday the 13th: JSON Attacks](#) by Alvaro Munoz and Oleksandr Mirosh
- [Severe Deserialization Issues Also Affect .NET, Not Just Java](#) by Catalin Cimpanu
- ysoserial.net exploit collection by Alvaro Munoz

Thanks

- [Markus Wulfstange](#) — for bringing up the problem to my attention
- [James Forshaw](#) — for the great blog posts, papers and talks on the subject
- [Alvaro Munoz](#), Oleksandr Mirosh — for the awesome educational ysoserial.net project
- [Chris Frohoff](#) — for the original ysoserial Java project
- [Levi Broderick](#) — for more malicious gadgets

License

MIT License.